

2017-12-23 TRAFFIC ANALYSIS EXERCISE: ANSWERS

CARLFORCE!

YOUR TASK

Review the pcap and figure out who got infected with what.

ANSWERS

IP address: **172.16.1.67**

Host name: **JERSEY-SHORE-1A**

User account name: **master.shake**

Activity: Emotet malware infection, probably from malspam

IP address: **172.16.1.89**

Host name: **JERSEY-SHORE-2D**

User account name: **frylock**

Activity: NanoCore RAT malware infection, probably from a malicious Word document

IP address: **172.16.1.141**

Host name: **JERSEY-SHORE-1F**

User account name: **carl.brutanandilews**

Activity: Tempedreve malware infection, probably from a file named **21Payment Slip.exe**

IP address: **172.16.1.201**

Host name: **NEWARK-1A**

User account name: **meatwad**

Activity: GlobelImposter malware infection, probably from Necurs Botnet malspam

INVESTIGATION DETAILS

INTRODUCTION

People reviewing this type of network traffic must have a solid knowledge of IPv4 networking. I gained the knowledge years ago by studying for my Network+ certification, but this is something people can pick up through Google searches. In my years of working with Security Operations Center (SOC) analysts, a good deal of problems came from analysts not fully understanding some fairly standard networking concepts.

With any pcap of traffic having multiple Windows hosts on a company network, these Windows hosts should all fall under some sort of non-routable IP address. These IP addresses will either be class A for addresses falling under 10.0.0.0/8, class B for 172.16.0.0/12, or class C for 192.168.0.0/16. Look up CIDR notation on Google if you don't understand how the slashes are being used here.

As always, I recommend you set up Wireshark according to the tutorials I've documented at: <http://malware-traffic-analysis.net/tutorials/index.html>

2017-12-23 TRAFFIC ANALYSIS EXERCISE: ANSWERS

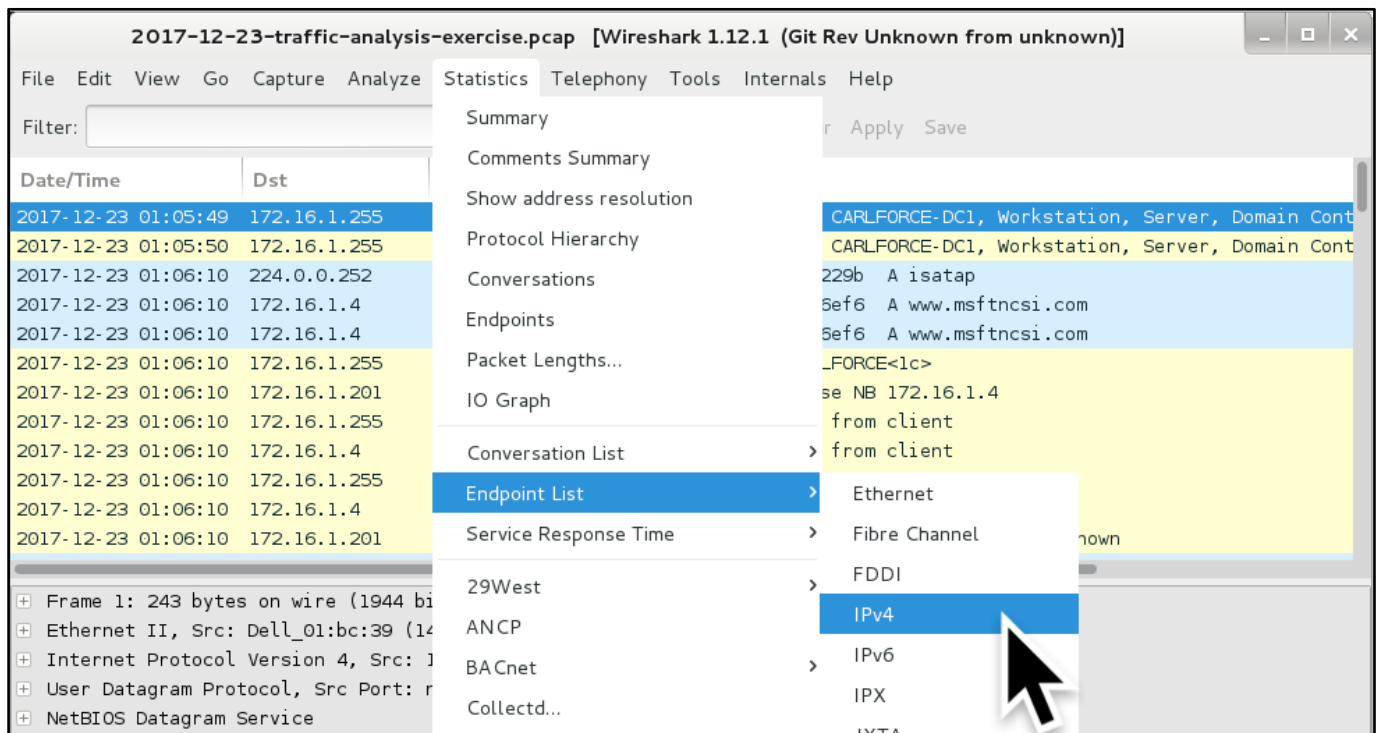
In our exercise pcap, we have five IP addresses for the internal (non-routable) IPv4 network. They break down as follows:

- **172.16.1.4** - The Active Directory (AD) server/Domain Controller (DC) for carlforce.com and DNS server for the internal network - host name: **CARLFORCE-DC1**
- **172.16.1.67** - host name: **jersey-shore-1a** - user account name: **master.shake**
- **172.16.1.89** - host name: **jersey-shore-2c** - user account name: **frylock**
- **172.16.1.141** - host name: **jersey-shore-1f** - user account name: **carl.brutananandilews**
- **172.16.1.201** - host name: **newark-1a** - user account name: **meatwad**

This traffic analysis exercise is my first to introduce a DC. It provides an example of Kerberos traffic on a company's Windows-based network. Kerberos traffic (usually on TCP port 88) is very useful to identify the names of user accounts on Windows computers. The user account information is stored on an AD server/DC, and users must sign in through the server as they log into their computers on the network. The domain for our fictional company is carlforce.com, and the users are **frylock**, **master.shake**, **meatwad**, and **carl.brutananadilews**. (The last name for Carl is Brutananadilewski, but there's apparently a 20-character limit on a Windows account's username.)

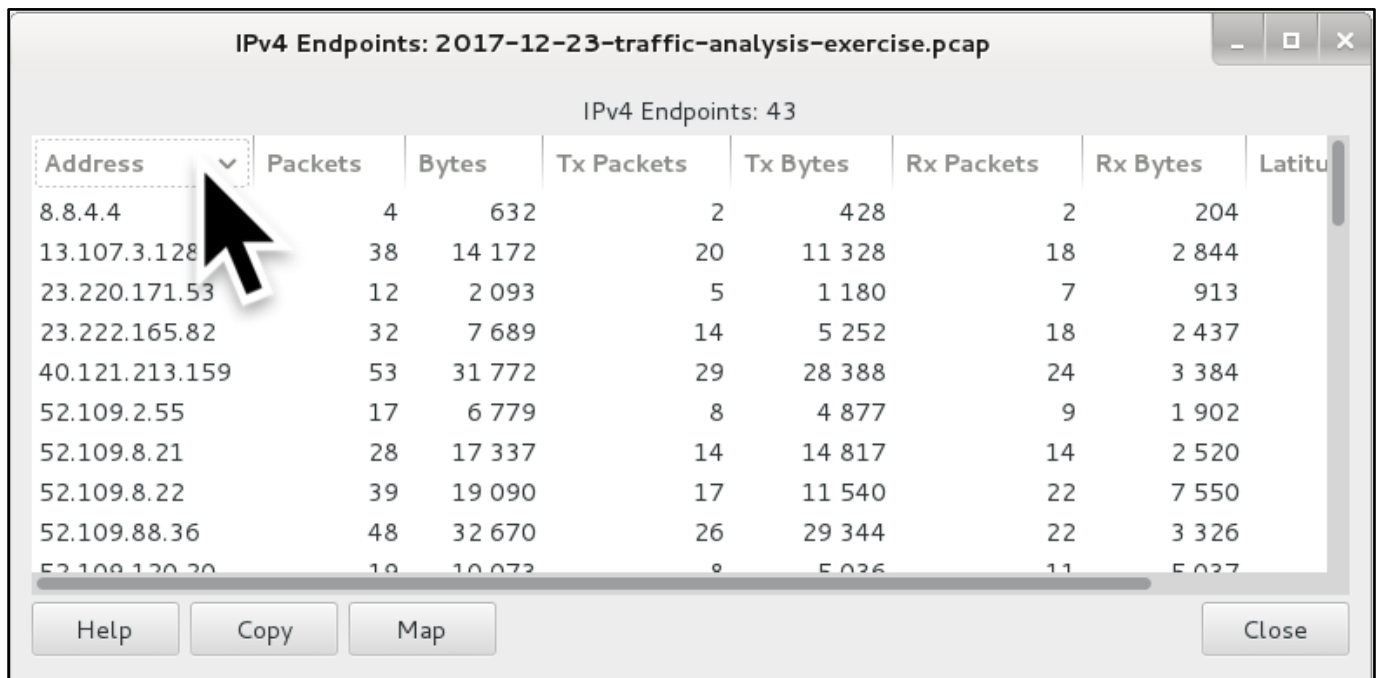
HOW TO DETERMINE THE DIFFERENT HOSTS IN THE PCAP

Open the pcap in Wireshark, go to the **Statistics** menu, and select **Endpoints**.



From there, sort on the address column.

2017-12-23 TRAFFIC ANALYSIS EXERCISE: ANSWERS



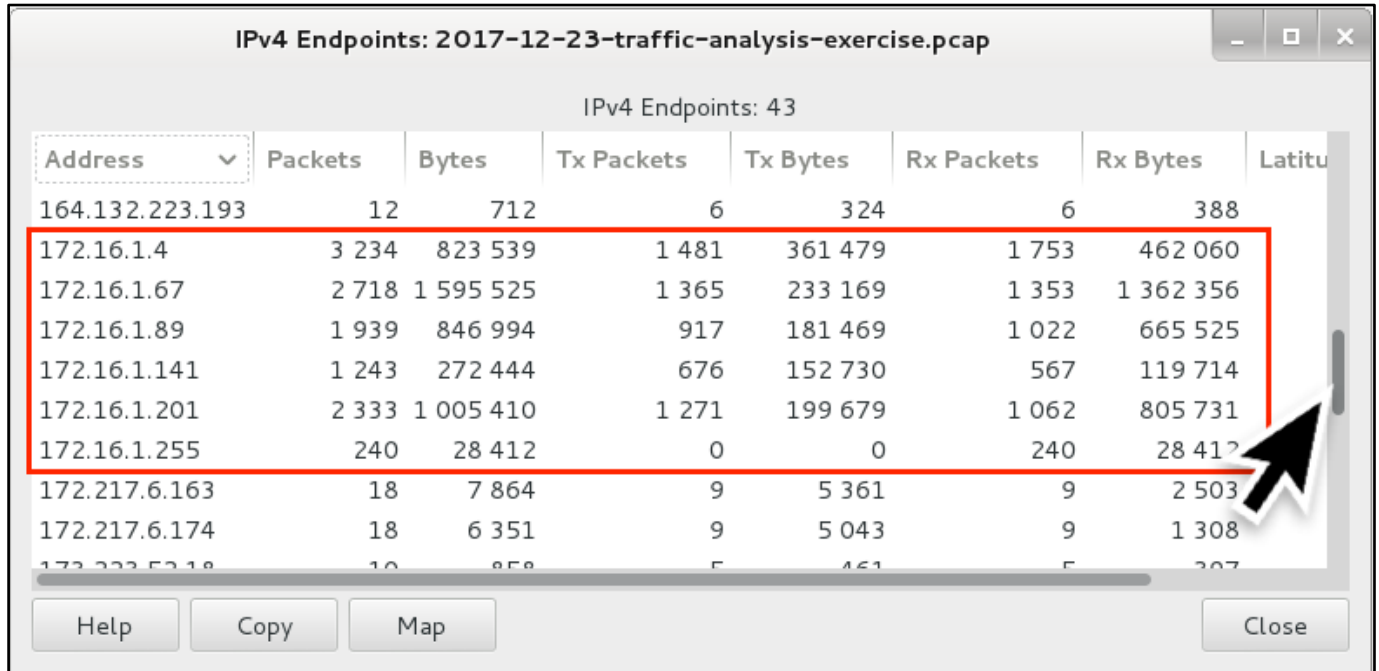
IPv4 Endpoints: 2017-12-23-traffic-analysis-exercise.pcap

IPv4 Endpoints: 43

Address	Packets	Bytes	Tx Packets	Tx Bytes	Rx Packets	Rx Bytes	Latitude
8.8.4.4	4	632	2	428	2	204	
13.107.3.128	38	14 172	20	11 328	18	2 844	
23.220.171.53	12	2 093	5	1 180	7	913	
23.222.165.82	32	7 689	14	5 252	18	2 437	
40.121.213.159	53	31 772	29	28 388	24	3 384	
52.109.2.55	17	6 779	8	4 877	9	1 902	
52.109.8.21	28	17 337	14	14 817	14	2 520	
52.109.8.22	39	19 090	17	11 540	22	7 550	
52.109.88.36	48	32 670	26	29 344	22	3 326	
52.109.120.20	18	10 072	8	5 036	11	5 037	

Help Copy Map Close

Then scroll down to look for addresses in the 10.0.0.0/8 range, the 172.16.0.0/12 range, or the 192.168.0.0/16 range. In this pcap, we see the five IP addresses discussed earlier, plus 172.16.1.255 which is the broadcast address for that network segment.



IPv4 Endpoints: 2017-12-23-traffic-analysis-exercise.pcap

IPv4 Endpoints: 43

Address	Packets	Bytes	Tx Packets	Tx Bytes	Rx Packets	Rx Bytes	Latitude
164.132.223.193	12	712	6	324	6	388	
172.16.1.4	3 234	823 539	1 481	361 479	1 753	462 060	
172.16.1.67	2 718	1 595 525	1 365	233 169	1 353	1 362 356	
172.16.1.89	1 939	846 994	917	181 469	1 022	665 525	
172.16.1.141	1 243	272 444	676	152 730	567	119 714	
172.16.1.201	2 333	1 005 410	1 271	199 679	1 062	805 731	
172.16.1.255	240	28 412	0	0	240	28 412	
172.217.6.163	18	7 864	9	5 361	9	2 503	
172.217.6.174	18	6 351	9	5 043	9	1 308	
172.222.52.18	10	858	5	461	5	397	

Help Copy Map Close

From there, we can get the host names by filtering on SMB traffic for the individual Windows hosts. For example, filtering on **ip.addr eq 172.16.1.4 and smb** should give you:

2017-12-23 TRAFFIC ANALYSIS EXERCISE: ANSWERS

Filter: ip.addr eq 172.16.1.4 and smb						Expression...	Clear	Apply	Save
Date/Time	Src	port	Dst	port	Info				
2017-12-23 01:05:49	172.16.1.4	138	172.16.1.255	138	Host Announcement CARLFORCE-DC1, Workstation, Server, Domain				
2017-12-23 01:05:50	172.16.1.4	138	172.16.1.255	138	Host Announcement CARLFORCE-DC1, Workstation, Server, Domain				
2017-12-23 01:06:10	172.16.1.201	138	172.16.1.4	138	SAM LOGON request from client				
2017-12-23 01:06:10	172.16.1.4	138	172.16.1.201	138	SAM Active Directory Response - user unknown				
2017-12-23 01:06:10	172.16.1.201	138	172.16.1.4	138	SAM LOGON request from client				
2017-12-23 01:06:10	172.16.1.4	138	172.16.1.201	138	SAM Active Directory Response - user unknown				
Frame 1: 243 bytes on wire (1944 bits), 243 bytes captured (1944 bits)									
Ethernet II, Src: Dell_01:bc:39 (14:fe:b5:01:bc:39), Dst: Broadcast (ff:ff:ff:ff:ff:ff)									
Internet Protocol Version 4, Src: 172.16.1.4 (172.16.1.4), Dst: 172.16.1.255 (172.16.1.255)									
User Datagram Protocol, Src Port: netbios-dgm (138), Dst Port: netbios-dgm (138)									
NetBIOS Datagram Service									
SMB (Server Message Block Protocol)									
SMB MailSlot Protocol									
Microsoft Windows Browser Protocol									
Command: Host Announcement (0x01)									
Update Count: 0									
Update Periodicity: 12 minutes									
Host Name: CARLFORCE-DC1									
Windows version: Windows 7 or Windows Server 2008 R2									
OS Major Version: 6									

This shows 172.16.1.4 broadcasting to the network segment that its host name is **CARLFORCE-DC1**.

If we try filtering on **ip.addr eq 172.16.1.67 and smb** and scroll through the results, we should find that IP address broadcasting to the network segment that its host name is **JERSEY-SHORE-1A**.

Filter: ip.addr eq 172.16.1.67 and smb						Expression...	Clear	Apply	Save	Filter	Filter	Filter	Filter	Filter
Date/Time	Src	port	Dst	port	Info									
2017-12-23 01:09:07	172.16.1.67	138	172.16.1.255	138	Get Backup List Request									
2017-12-23 01:10:28	172.16.1.67	138	172.16.1.255	138	Host Announcement JERSEY-SHORE-1A, Workstation, Server, NT W									
2017-12-23 01:10:29	172.16.1.67	138	172.16.1.255	138	Host Announcement JERSEY-SHORE-1A, Workstation, Server, NT W									
2017-12-23 01:18:26	172.16.1.67	138	172.16.1.255	138	Host Announcement JERSEY-SHORE-1A, Workstation, Server, NT W									
2017-12-23 01:18:27	172.16.1.67	138	172.16.1.255	138	Host Announcement JERSEY-SHORE-1A, Workstation, Server, NT W									
2017-12-23 01:22:19	172.16.1.67	445	172.16.1.4	445	Negotiate Protocol Request									
Frame 3189: 243 bytes on wire (1944 bits), 243 bytes captured (1944 bits)														
Ethernet II, Src: Acer_d7:40:b2 (00:01:24:d7:40:b2), Dst: Broadcast (ff:ff:ff:ff:ff:ff)														
Internet Protocol Version 4, Src: 172.16.1.67 (172.16.1.67), Dst: 172.16.1.255 (172.16.1.255)														
User Datagram Protocol, Src Port: netbios-dgm (138), Dst Port: netbios-dgm (138)														
NetBIOS Datagram Service														
SMB (Server Message Block Protocol)														
SMB MailSlot Protocol														
Microsoft Windows Browser Protocol														
Command: Host Announcement (0x01)														
Update Count: 0														
Update Periodicity: 8 minutes														
Host Name: JERSEY-SHORE-1A														
Windows version: Windows 7 or Windows Server 2008 R2														
OS Major Version: 6														

2017-12-23 TRAFFIC ANALYSIS EXERCISE: ANSWERS

Want a quicker way to find these broadcast announcements? Try using **browser.server** instead of **smb**. In fact, if you just filter on **browser.server** and sort the results by Source IP address, you should find host announcements with host names from four of the five IP addresses.

Filter: browser.server		Expression... Clear Apply Save Filter Filter Filter Filter Filter									
Date/Time	Src	port	Dst	port	Info						
2017-12-23 01:10:09	172.16.1.141	138	172.16.1.255	138	Host Announcement NEWARK-1A, Workstation, Server, NT Worksta						
2017-12-23 01:10:10	172.16.1.141	138	172.16.1.255	138	Host Announcement NEWARK-1A, Workstation, Server, NT Worksta						
2017-12-23 01:18:08	172.16.1.201	138	172.16.1.255	138	Host Announcement NEWARK-1A, Workstation, Server, NT Worksta						
2017-12-23 01:18:09	172.16.1.201	138	172.16.1.255	138	Host Announcement NEWARK-1A, Workstation, Server, NT Worksta						
2017-12-23 01:30:08	172.16.1.201	138	172.16.1.255	138	Host Announcement NEWARK-1A, Workstation, Server, NT Worksta						
2017-12-23 01:30:08	172.16.1.201	138	172.16.1.255	138	Host Announcement NEWARK-1A, Workstation, Server, NT Worksta						
2017-12-23 01:42:06	172.16.1.201	138	172.16.1.255	138	Host Announcement NEWARK-1A, Workstation, Server, NT Worksta						
2017-12-23 01:42:06	172.16.1.201	138	172.16.1.255	138	Host Announcement NEWARK-1A, Workstation, Server, NT Worksta						
2017-12-23 01:05:49	172.16.1.4	138	172.16.1.255	138	Host Announcement CARLFORCE-DC1, Workstation, Server, Domain						
2017-12-23 01:05:50	172.16.1.4	138	172.16.1.255	138	Host Announcement CARLFORCE-DC1, Workstation, Server, Domain						
2017-12-23 01:17:47	172.16.1.4	138	172.16.1.255	138	Host Announcement CARLFORCE-DC1, Workstation, Server, Domain						
2017-12-23 01:17:47	172.16.1.4	138	172.16.1.255	138	Host Announcement CARLFORCE-DC1, Workstation, Server, Domain						
2017-12-23 01:29:48	172.16.1.4	138	172.16.1.255	138	Host Announcement CARLFORCE-DC1, Workstation, Server, Domain						
2017-12-23 01:29:49	172.16.1.4	138	172.16.1.255	138	Host Announcement CARLFORCE-DC1, Workstation, Server, Domain						
2017-12-23 01:41:49	172.16.1.4	138	172.16.1.255	138	Host Announcement CARLFORCE-DC1, Workstation, Server, Domain						
2017-12-23 01:41:50	172.16.1.4	138	172.16.1.255	138	Host Announcement CARLFORCE-DC1, Workstation, Server, Domain						
2017-12-23 01:10:28	172.16.1.67	138	172.16.1.255	138	Host Announcement JERSEY-SHORE-1A, Workstation, Server, NT W						
2017-12-23 01:10:29	172.16.1.67	138	172.16.1.255	138	Host Announcement JERSEY-SHORE-1A, Workstation, Server, NT W						
2017-12-23 01:18:26	172.16.1.67	138	172.16.1.255	138	Host Announcement JERSEY-SHORE-1A, Workstation, Server, NT W						
2017-12-23 01:18:27	172.16.1.67	138	172.16.1.255	138	Host Announcement JERSEY-SHORE-1A, Workstation, Server, NT W						
2017-12-23 01:30:26	172.16.1.67	138	172.16.1.255	138	Host Announcement JERSEY-SHORE-1A, Workstation, Server, NT W						
2017-12-23 01:30:26	172.16.1.67	138	172.16.1.255	138	Host Announcement JERSEY-SHORE-1A, Workstation, Server, NT W						
2017-12-23 01:42:28	172.16.1.67	138	172.16.1.255	138	Host Announcement JERSEY-SHORE-1A, Workstation, Server, NT W						
2017-12-23 01:42:29	172.16.1.67	138	172.16.1.255	138	Host Announcement JERSEY-SHORE-1A, Workstation, Server, NT W						
2017-12-23 01:10:23	172.16.1.89	138	172.16.1.255	138	Host Announcement JERSEY-SHORE-2C, Workstation, Server, NT W						
2017-12-23 01:10:24	172.16.1.89	138	172.16.1.255	138	Host Announcement JERSEY-SHORE-2C, Workstation, Server, NT W						
2017-12-23 01:18:22	172.16.1.89	138	172.16.1.255	138	Host Announcement JERSEY-SHORE-2C, Workstation, Server, NT W						

But what about 172.16.1.141? That one doesn't have a host announcement from the SMB traffic in the pcap. How do we find the host name for that one? Usually, I try different tactics, like filtering on the NetBIOS name service (NBNS) traffic or DHCP traffic (UDP port 67 or 68) like I've discussed in answers for previous traffic analysis exercises.

Unfortunately, that doesn't help here. However, sometimes you can find hints in the DNS traffic. If we filter on **ip.addr eq 172.16.1.141 and dns**, we find some SOA type DNS queries for **Jersey-Shore-1f.carlforce.com**, indicating the Windows host name for this IP address is **JERSEY-SHORE-1F**.

2017-12-23 TRAFFIC ANALYSIS EXERCISE: ANSWERS

Filter: ip.addr eq 172.16.1.141 and dns						Expression...	Clear	Apply	Save
Date/Time	Src	port	Dst	port	Info				
2017-12-23 01:06:24	172.16.1.141	54070	172.16.1.4	53	Standard query 0x4b06 SRV _ldap_tcp.carlforce.com				
2017-12-23 01:06:24	172.16.1.4	53	172.16.1.141	54070	Standard query response 0x4b06 SRV 0 100 389 carlforce-dc:				
2017-12-23 01:06:24	172.16.1.141	58610	172.16.1.4	53	Standard query 0x902a A carlforce-dc1.carlforce.com				
2017-12-23 01:06:24	172.16.1.4	53	172.16.1.141	58610	Standard query response 0x902a A 172.16.1.4				
2017-12-23 01:06:26	172.16.1.141	64421	172.16.1.4	53	Standard query 0xe236 SOA Jersey-Shore-1f.carlforce.com				
2017-12-23 01:06:26	172.16.1.4	53	172.16.1.141	64421	Standard query response 0xe236				
2017-12-23 01:06:26	172.16.1.141	62147	172.16.1.4	53	Dynamic update 0x4fae SOA carlforce.com				

This is where the Kerberos traffic can help. There's a field in Kerberos traffic named **KerberosString** that you can filter on. All host names end with a dollar sign (\$). The Wireshark filter is:

- **kerberos.KerberosString contains \$**

Combine that with the IP address, and you have the following Wireshark filter:

- **ip.addr eq 172.16.1.141 and kerberos.KerberosString contains \$**

Each frame in the results should have the host name for 172.16.1.141 if we scroll through the Kerberos information as shown below.

Filter: ip.addr eq 172.16.1.141 and kerberos.KerberosString						Expression...	Clear	Apply	Save
Date/Time	Src	port	Dst	port	Info				
2017-12-23 01:06:24	172.16.1.141	49158	172.16.1.4	88	AS-REQ				
2017-12-23 01:06:24	172.16.1.141	49159	172.16.1.4	88	AS-REQ				
2017-12-23 01:06:24	172.16.1.4	88	172.16.1.141	49159	AS-REP				
2017-12-23 01:06:24	172.16.1.4	88	172.16.1.141	49160	TGS-REP				
2017-12-23 01:06:24	172.16.1.141	49162	172.16.1.4	88	AS-REQ				
2017-12-23 01:06:24	172.16.1.141	49163	172.16.1.4	88	AS-REQ				
2017-12-23 01:06:24	172.16.1.4	88	172.16.1.141	49163	AS-REP				
.....									
+ Frame 425: 1665 bytes on wire (13320 bits), 1665 bytes captured (13320 bits)									
+ Ethernet II, Src: Dell_01:bc:39 (14:fe:b5:01:bc:39), Dst: BiostarM_dc:2b:64 (00:30:67:dc:2b:64)									
+ Internet Protocol Version 4, Src: 172.16.1.4 (172.16.1.4), Dst: 172.16.1.141 (172.16.1.141)									
+ Transmission Control Protocol, Src Port: kerberos (88), Dst Port: 49159 (49159), Seq: 1, Ack: 323, Len: 1611									
- Kerberos									
+ Record Mark: 1607 bytes									
- as-rep									
pvno: 5									
msg-type: krb-as-rep (11)									
+ padata: 1 item									
crealm: CARLFORCE.COM									
- cname									
name-type: kRB5-NT-PRINCIPAL (1)									
- name-string: 1 item									
KerberosString: JERSEY-SHORE-1F\$									
+ ticket									
- enc-part									

Of note, we can find the user account name using this same method, but we want KerberosString results that don't have a dollar sign in the name. This one's a little trickier,

2017-12-23 TRAFFIC ANALYSIS EXERCISE: ANSWERS

because we have to specify that we're still looking for the name string. Here's the Wireshark filter to help us find what the user account is on 172.16.1.141:

- ***ip.addr eq 172.16.1.141 and kerberos.name_type == 1 and !(kerberos.KerberosString contains \$)***

This is where we find user account **carl.brutananadilews** for that host name and IP address.

Filter: `ip.addr eq 172.16.1.141 and kerberos.name_type == 1` Expression... Clear Apply Save

Date/Time	Src	port	Dst	port	Info
2017-12-23 01:06:49	172.16.1.141	49170	172.16.1.4	88	AS-REQ
2017-12-23 01:06:49	172.16.1.141	49171	172.16.1.4	88	AS-REQ
2017-12-23 01:06:49	172.16.1.4	88	172.16.1.141	49171	AS-REP
2017-12-23 01:06:49	172.16.1.4	88	172.16.1.141	49172	TGS-REP
2017-12-23 01:15:55	172.16.1.4	88	172.16.1.141	49187	TGS-REP
2017-12-23 01:15:56	172.16.1.4	88	172.16.1.141	49190	TGS-REP
2017-12-23 01:15:56	172.16.1.4	88	172.16.1.141	49193	TGS-REP

Frame 1305: 1635 bytes on wire (13080 bits), 1635 bytes captured (13080 bits)

Ethernet II, Src: Dell_01:bc:39 (14:fe:b5:01:bc:39), Dst: BiostarM_dc:2b:64 (00:30:67:dc:2b:64)

Internet Protocol Version 4, Src: 172.16.1.4 (172.16.1.4), Dst: 172.16.1.141 (172.16.1.141)

Transmission Control Protocol, Src Port: kerberos (88), Dst Port: 49172 (49172), Seq: 1, Ack: 1551, Len: 1581

Kerberos

Record Mark: 1577 bytes

tgts-rep

pvno: 5

msg-type: krb-tgs-rep (13)

crealm: CARLFORCE.COM

cname

name-type: KRBS-NT-PRINCIPAL (1)

name-string: 1 item

KerberosString: carl.brutananadilews

ticket

In fact, if we want to find the user account name on each host, we can filter on requests with KerberosString fields where the source IP isn't 172.16.1.4, and we have a handy list, where we can check each of the four IP addresses. Try the following filter:

- ***!(ip.src eq 172.16.1.4) and kerberos.name_type == 1 and !(kerberos.KerberosString contains \$)***

Filter: `!(ip.src eq 172.16.1.4) and kerberos.name_type == 1` Expression... Clear Apply Save

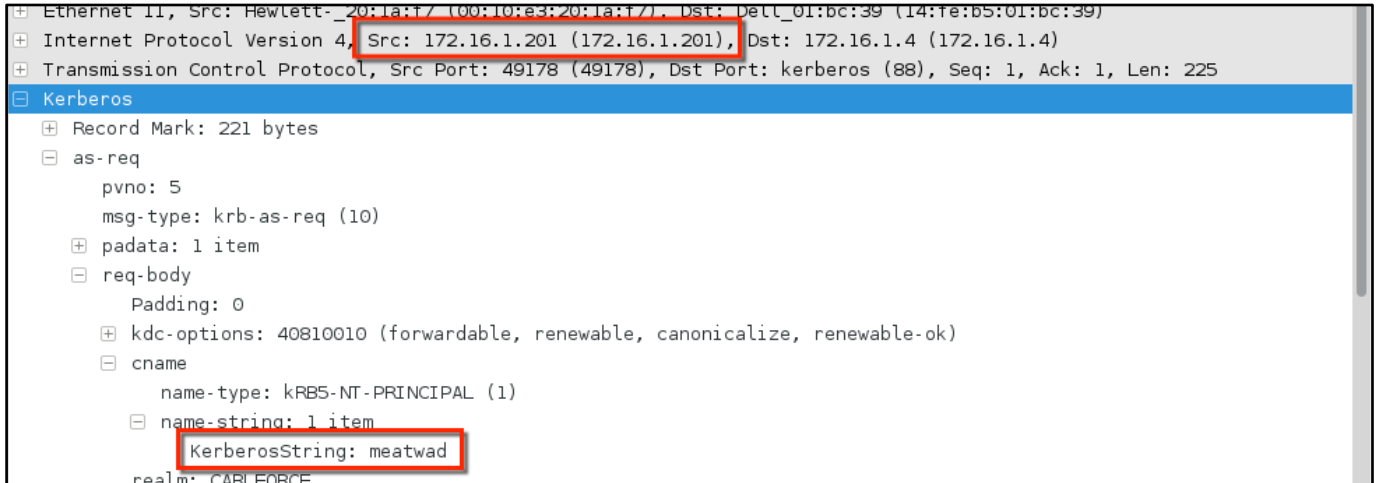
Date/Time	Src	port	Dst	port	Info
2017-12-23 01:06:21	172.16.1.201	49178	172.16.1.4	88	AS-REQ
2017-12-23 01:06:21	172.16.1.201	49179	172.16.1.4	88	AS-REQ
2017-12-23 01:06:38	172.16.1.89	49180	172.16.1.4	88	AS-REQ
2017-12-23 01:06:38	172.16.1.89	49181	172.16.1.4	88	AS-REQ
2017-12-23 01:06:49	172.16.1.141	49170	172.16.1.4	88	AS-REQ
2017-12-23 01:06:49	172.16.1.141	49171	172.16.1.4	88	AS-REQ
2017-12-23 01:08:41	172.16.1.67	49186	172.16.1.4	88	AS-REQ

Frame 304: 279 bytes on wire (2232 bits), 279 bytes captured (2232 bits)

Ethernet II, Src: Hewlett_20:1a:f7 (00:10:03:20:1a:f7), Dst: Dell_01:bc:39 (14:fe:b5:01:bc:39)

2017-12-23 TRAFFIC ANALYSIS EXERCISE: ANSWERS

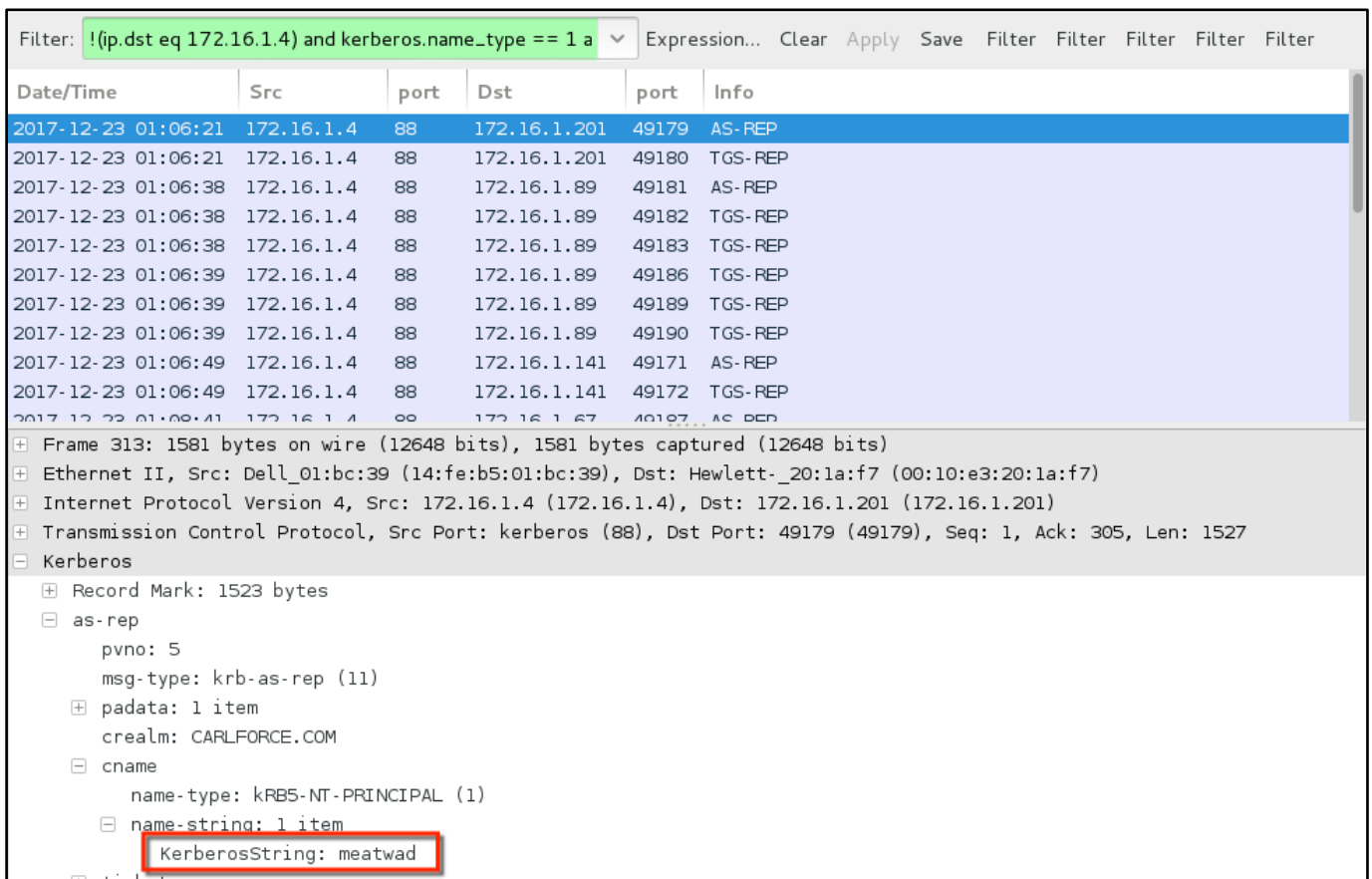
Notice the above results have all four IP addresses, where we can check the names.



We can do the same thing for the responses by changing *ip.src* to *ip.dst* in the Wireshark filter.

- **!(ip.dst eq 172.16.1.4) and kerberos.name_type == 1 and !(kerberos.KerberosString contains \$)**

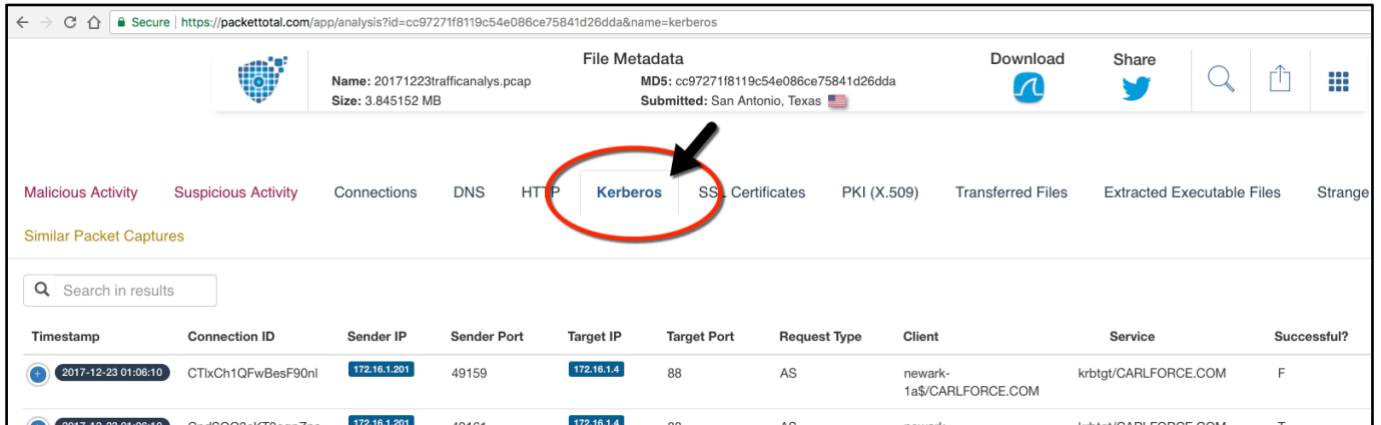
Now the IP addresses for each of the Windows hosts are in the column for the destination IP.



2017-12-23 TRAFFIC ANALYSIS EXERCISE: ANSWERS

I'm sure there are different ways you can find this information, because I'm still learning new tricks as I develop these traffic analysis exercises. Feel free to experiment and find the best way for you.

Another trick is to send the pcap to PacketTotal (already done, which you can find [here](#)) and review the Kerberos tab.



File Metadata

Name: 20171223trafficanalys.pcap
Size: 3.845152 MB

MD5: cc97271f8119c54e086ce75841d26dda
Submitted: San Antonio, Texas

Download Share

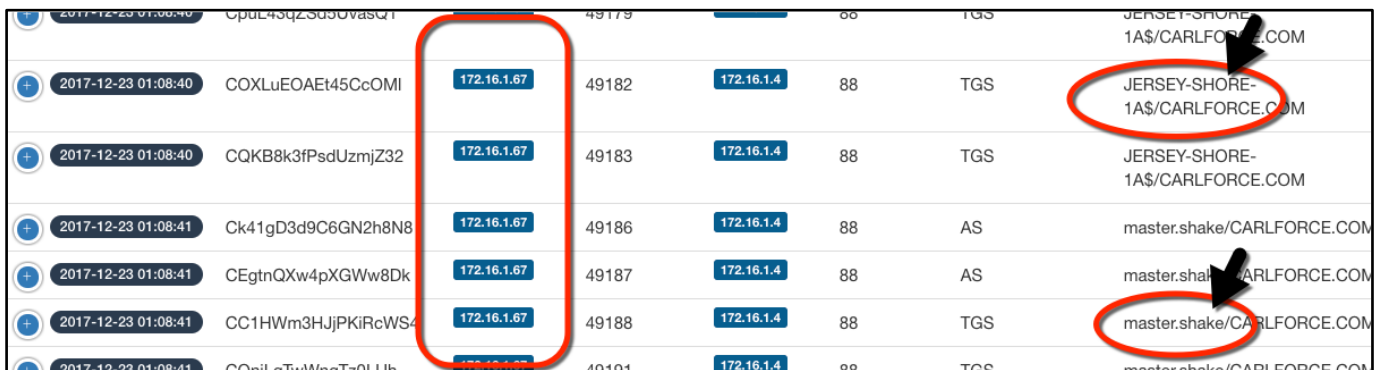
Malicious Activity Suspicious Activity Connections DNS HTTP **Kerberos** SSL Certificates PKI (X.509) Transferred Files Extracted Executable Files Strange

Similar Packet Captures

Search in results

Timestamp	Connection ID	Sender IP	Sender Port	Target IP	Target Port	Request Type	Client	Service	Successful?
2017-12-23 01:06:10	CTixCh1QFwBesF90nl	172.16.1.201	49159	172.16.1.4	88	AS	newark-1a\$/CARLFORCE.COM	krbtgt/CARLFORCE.COM	F
2017-12-23 01:06:10	CedSQ02ekT22gnZee	172.16.1.201	49161	172.16.1.4	88	AS	newark-	krbtgt/CARLFORCE.COM	T

You can search through the Kerberos section to correlate the host names with the user account names on the different IP addresses, as shown in the image below.



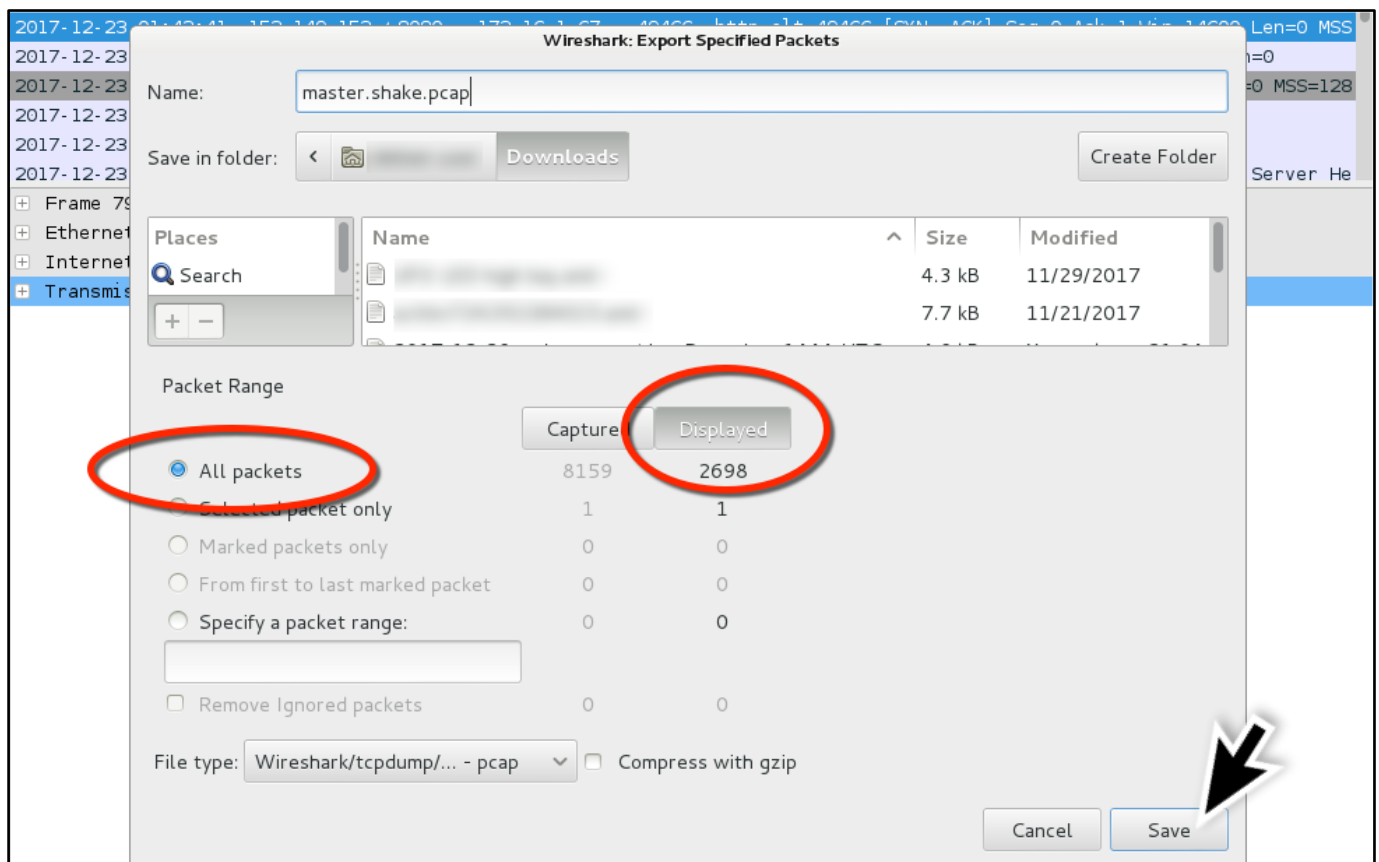
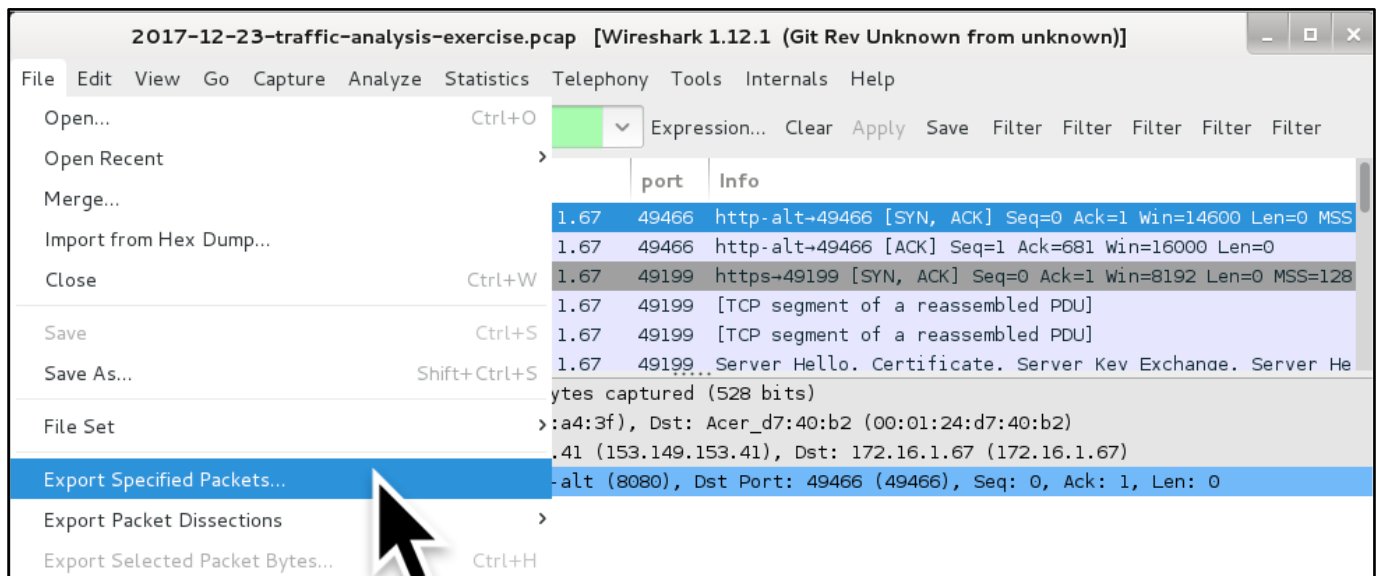
Timestamp	Connection ID	Sender IP	Sender Port	Target IP	Target Port	Request Type	Client	Service	Successful?
2017-12-23 01:06:10	CpUL43qZ3u3UvasQ1	172.16.1.67	49179	172.16.1.4	88	TGS	JERSEY-SHORE-1A\$/CARLFORCE.COM	JERSEY-SHORE-1A\$/CARLFORCE.COM	
2017-12-23 01:08:40	COXLuEOAEt45CcOMI	172.16.1.67	49182	172.16.1.4	88	TGS	JERSEY-SHORE-1A\$/CARLFORCE.COM	JERSEY-SHORE-1A\$/CARLFORCE.COM	
2017-12-23 01:08:40	CQKB8k3fPsdUzmjZ32	172.16.1.67	49183	172.16.1.4	88	TGS	JERSEY-SHORE-1A\$/CARLFORCE.COM	JERSEY-SHORE-1A\$/CARLFORCE.COM	
2017-12-23 01:08:41	Ck41gD3d9C6GN2h8N8	172.16.1.67	49186	172.16.1.4	88	AS	master.shake/CARLFORCE.COM	master.shake/CARLFORCE.COM	
2017-12-23 01:08:41	CEgtnQXw4pXGWw8Dk	172.16.1.67	49187	172.16.1.4	88	AS	master.shake/CARLFORCE.COM	master.shake/CARLFORCE.COM	
2017-12-23 01:08:41	CC1HWm3HJjPKiRcWS4	172.16.1.67	49188	172.16.1.4	88	TGS	master.shake/CARLFORCE.COM	master.shake/CARLFORCE.COM	
2017-12-23 01:08:41	COoLpTjWwqTz0LlU	172.16.1.67	49191	172.16.1.4	88	TGS	master.shake/CARLFORCE.COM	master.shake/CARLFORCE.COM	

WHAT HAPPENED WITH MASTER.SHAKE ON JERSEY-SHORE-1A (172.16.1.67)?

First, let's filter on *ip.addr eq 172.16.1.67* and export the results to a new pcap.

Filter: ip.addr eq 172.16.1.67		Expression...	Clear	Apply	Save	Filter	Filter	Filter	Filter	Filter
Date/Time	Src	port	Dst	port	Info					
2017-12-23 01:42:41	153.149.153.4	8080	172.16.1.67	49466	http-alt-49466 [SYN, ACK] Seq=0 Ack=1 Win=14600 Len=0 MSS=					
2017-12-23 01:42:41	153.149.153.4	8080	172.16.1.67	49466	http-alt-49466 [ACK] Seq=1 Ack=681 Win=16000 Len=0					
2017-12-23 01:16:08	157.56.96.123	443	172.16.1.67	49199	https-49199 [SYN, ACK] Seq=0 Ack=1 Win=8192 Len=0 MSS=128					
2017-12-23 01:16:08	157.56.96.123	443	172.16.1.67	49199	[TCP segment of a reassembled PDU]					
2017-12-23 01:16:08	157.56.96.123	443	172.16.1.67	49199	[TCP segment of a reassembled PDU]					
2017-12-23 01:16:08	157.56.96.123	443	172.16.1.67	49199	Server Hello, Certificate, Server Key Exchange, Server He					

2017-12-23 TRAFFIC ANALYSIS EXERCISE: ANSWERS



The first thing I usually do is look at the HTTP request, so let's filter on **http.request** to see what we have.

2017-12-23 TRAFFIC ANALYSIS EXERCISE: ANSWERS

Filter: http.request Expression... Clear Apply Save					
Date/Time	Dst	port	Host	Info	
2017-12-23 01:08:12	185.2.4.53	80	www.fundtel.es	GET /Purchases-2017/ HTTP/1.1	
2017-12-23 01:08:45	78.46.96.236	80	www.enjoyveganrecipes.com	GET /j7iHZm/ HTTP/1.1	
2017-12-23 01:09:01	62.210.253.72	8080	62.210.253.72:8080	POST / HTTP/1.1	
2017-12-23 01:09:04	62.210.253.72	8080	62.210.253.72:8080	POST / HTTP/1.1	
2017-12-23 01:16:34	23.222.165.82	80	www.microsoft.com	GET /pkiops/crl/Microsoft%20Update%20Signing%20CA%202	
2017-12-23 01:16:39	23.222.165.82	80	www.microsoft.com	GET /pkiops/crl/Microsoft%20Update%20Signing%20CA%202	
2017-12-23 01:17:16	23.220.171.53	80	go.microsoft.com	GET /fwlink/?LinkID=121721&clcid=0x409&arch=x64&eng=1	
2017-12-23 01:17:47	23.220.171.53	80	go.microsoft.com	GET /fwlink/?LinkID=260974&clcid=0x409&NRI=true&arch=	
2017-12-23 01:17:48	23.222.165.82	80	www.microsoft.com	GET /security/encyclopedia/nispackages.aspx?NRI=true&	
2017-12-23 01:24:05	62.210.253.72	8080	62.210.253.72:8080	POST / HTTP/1.1	
2017-12-23 01:39:06	62.210.253.72	8080	62.210.253.72:8080	POST / HTTP/1.1	
2017-12-23 01:40:39	220.227.247.35	7080	220.227.247.35:7080	POST / HTTP/1.1	
2017-12-23 01:41:42	220.227.247.39	7080	220.227.247.39:7080	POST / HTTP/1.1	
2017-12-23 01:42:41	153.149.153.41	8080	153.149.153.41:8080	POST / HTTP/1.1	

Traffic patterns in the above image are similar to traffic patterns in Emotet malware infections from malspam. I've documented recent examples on 2017-11-29 ([link](#)) and 2017-12-27 ([link](#)). Furthermore, the image on the answers page for this traffic analysis exercise shows Emotet alerts on the traffic in Sguil on Security Onion.

SGUIL-0.9.0 - Connected To localhost									
File Query Reports Sound: Off ServerName: localhost Username: a UserID: 2									
RealTime Events Escalated Events									
ST	CNT	Date/Time	Src IP	SPort	Dst IP	DPort	Pr	Event Message	
RT	7	2017-12-23...	172.16.1.67	49197	62.210.253.72	8080	6	ETPRO TROJAN W32/Emotet.v4 Checkin 3	
RT	7	2017-12-23...	172.16.1.67	49197	62.210.253.72	8080	6	ETPRO TROJAN W32/Emotet.v4 Checkin 2	
RT	7	2017-12-23...	172.16.1.67	49197	62.210.253.72	8080	6	ETPRO TROJAN W32/Emotet.v4 Checkin	
RT	52	2017-12-23...	185.22.184.127	443	172.16.1.89	49197	6	ETPRO TROJAN Nanocore SSL Certificate	
RT	52	2017-12-23...	185.22.184.127	443	172.16.1.89	49197	6	ETPRO CURRENT_EVENTS Observed Malicious SSL	
RT	38	2017-12-23	172.16.1.89	49197	185.22.184.127	443	6	ETPRO TROJAN Observed Malicious MalDoc DL Do	

WHAT HAPPENED WITH FRYLOCK ON JERSEY-SHORE-2C (172.16.1.89)?

Like we did in the previous example with Master Shake, let's filter on Frylock's traffic. Try filtering on **ip.addr eq 172.16.1.89** and export the results to a new pcap.

Got it? Good! In this new pcap, when we filter on **http.request**, the results are not very helpful. All we see is an IP address check at **checkup.dyndns.org**.

Filter: http.request Expression... Clear Apply Save					
Date/Time	Dst	port	Host	Info	
2017-12-23 01:13:06	216.146.43.70	80	checkip.dyndns.org	GET / HTTP/1.1	

2017-12-23 TRAFFIC ANALYSIS EXERCISE: ANSWERS

Let's see if there's any HTTPS traffic. Add **ssl.handshake.type** to the Wireshark filter, and try:

- **http.request or ssl.handshake.type == 1**

Date/Time	Dst	port	Host	Server Name	Info
2017-12-23 01:13:06	216.146.43.70	80	checkip.dyndns.org		GET / HTTP/1.1
2017-12-23 01:13:06	185.22.184.127	443		temizlikhizmetleri.net	Client Hello
2017-12-23 01:14:08	185.22.184.127	443		temizlikhizmetleri.net	Client Hello
2017-12-23 01:15:08	185.22.184.127	443		temizlikhizmetleri.net	Client Hello
2017-12-23 01:16:08	185.22.184.127	443		temizlikhizmetleri.net	Client Hello
2017-12-23 01:17:08	185.22.184.127	443		temizlikhizmetleri.net	Client Hello
2017-12-23 01:18:08	185.22.184.127	443		temizlikhizmetleri.net	Client Hello
2017-12-23 01:18:09	185.22.184.127	443		temizlikhizmetleri.net	Client Hello
2017-12-23 01:19:08	185.22.184.127	443		temizlikhizmetleri.net	Client Hello
2017-12-23 01:20:08	185.22.184.127	443		temizlikhizmetleri.net	Client Hello
2017-12-23 01:21:08	185.22.184.127	443		temizlikhizmetleri.net	Client Hello

Now we see several TCP streams of HTTPS traffic to **temizlikhizmetleri.net**. That still doesn't tell us what happened. A Google search on **temizlikhizmetleri.net +malware** returns two results from reverse.it/hybrid-analysis.com. If you review those, you'll find one is an .exe file, and the other is a Microsoft Word document. Further investigation shows the Word document retrieved the .exe file, and they are both tagged #maldoc #nanocore #rat.

Free Automated Malware Analysis Service – powered by Falcon Sandbox – Viewing online file analysis results for 'ork.exe' – Mozilla Firefox

Free Automated Mal... x +

https://www.hybrid-analysis.com/sample/d28eb505d8433f1a2e7196da38807ca: | Search

ork.exe

Analyzed on December 21st 2017 08:43:44 (CEST) running the *Kernelmode* monitor and action script *Heavy Anti-Evasion*
Guest System: Windows 7 32 bit, Home Premium, 6.1 (build 7601), Service Pack 1
Report generated by Falcon Sandbox v7.20 © Hybrid Analysis

Threat Score: 100/100
AV Multiscan: 19%
Labeled as: **Packed-TW**
Tagged as: **#maldoc, #nanocore, #rat**

Incident Response
Platform Intelligence
Indicators
File Details
Screenshots (1)
Hybrid Analysis (2)
Network Analysis
Community (0)

#maldoc, #nanocore, #rat

In fact, traffic from analysis of the Word document looks the same as our traffic. Finally, the image on the answers page for this traffic analysis exercise shows an alert for NanoCore RAT and a "MalDoc" alert associated with IP address 172.16.1.89.

2017-12-23 TRAFFIC ANALYSIS EXERCISE: ANSWERS

8...	172.16.1.67	49197	62.210.253.72	8080	6	ETPRO TROJAN W32/Emotet.v4 Checkin
8...	172.16.1.67	49197	62.210.253.72	8080	6	ETPRO TROJAN W32/Emotet.v4 Checkin
8...	185.22.184.127	443	172.16.1.89	49197	6	ETPRO TROJAN Nanocore SSL Certificate
8...	185.22.184.127	443	172.16.1.89	49197	6	ETPRO CURRENT_EVENTS Observed Malicious SSL Cert (MalDoc DL)
8...	172.16.1.89	49197	185.22.184.127	443	6	ETPRO TROJAN Observed Malicious MalDoc DL Domain In SNI (te...
8...	172.16.1.89	49198	216.146.43.70	80	6	ET POLICY External IP Lookup - checkip.dyndns.org
8...	172.16.1.201	49209	67.59.136.100	80	6	ET POLICY Internet Explorer 6 in use - Significant Security Risk
8...	67.59.136.100	80	172.16.1.201	49209	6	ETPRO TROJAN Locky JS Executable Payload Download

We can't be sure the document from the reverse.it analysis is same document that caused the infection, but it's a likely possibility.

WHAT HAPPENED WITH CARL.BRUTANANANDILEWS ON JERSEY-SHORE-1F (172.16.1.141)?

Like we did in the previous two examples, let's filter on the IP address for Carl. Try filtering on ***ip.addr eq 172.16.1.141*** and export the results to a new pcap.

If we filter on ***http.request*** in the new pcap, the results are not very helpful.

Filter:	http.request	▼	Expression...	Clear	Apply	Save
Date/Time	Dst	port	Host	Info		
2017-12-23 01:35:22	176.31.127.119	80	176.31.127.119	GET /pki/mscorp/crl/msitwww2.crl HTTP/1.1		
2017-12-23 01:41:21	173.223.52.193	80	www.msftncsi.com	GET /ncsi.txt HTTP/1.1		

That HTTP request to 176.31.127.119 is suspicious, but there must be something else. Even adding ***ssl.handshake.type == 1*** to the filter doesn't show us any more info.

Filter:	http.request or ssl.handshake.type == 1	▼	Expression...	Clear	Apply	Save
Date/Time	Dst	port	Host	Info		
2017-12-23 01:35:22	176.31.127.119	80	176.31.127.119	GET /pki/mscorp/crl/msitwww2.crl HTTP/1.1		
2017-12-23 01:41:21	173.223.52.193	80	www.msftncsi.com	GET /ncsi.txt HTTP/1.1		

What more can we look for? Let's see if there's any other TCP traffic by searching for SYN packets. For SYN packets, use ***tcp.flags eq 0x0002***. Since we know there's no HTTPS traffic, leave out the ***ssl.handshake.type == 1***. Also, if there are attempted TCP connections, there might be associated DNS queries with them. I would use the following search filter:

- ***http.request or (tcp.flags eq 0x0002 and !(ip.dst eq 172.16.1.0/24)) or dns.qry.name***

2017-12-23 TRAFFIC ANALYSIS EXERCISE: ANSWERS

In the above filter, I'm looking at HTTP requests and TCP SYN packets where the destination is not one of the IP addresses in the internet network. (Remember that Kerberos traffic, also TCP based?) There's still a lot to wade through. However, scroll through the results, and you'll find attempted TCP connections to ***gabby4u.linkpc.net*** at ***174.127.99.158*** over TCP port 2017.

Filter: http.request or (tcp.flags eq 0x0002 and !(ip.dst eq 174.127.99.158)) Expression... Clear Apply Save Filter Filter Filter Filter Filter				
Date/Time	Dst	port	Host	Info
2017-12-23 01:41:24	224.0.0.252	5353		Standard query 0x1758 A isatap
2017-12-23 01:42:24	172.16.1.4	53		Standard query 0x9ecf A gabby4u.linkpc.net
2017-12-23 01:42:24	172.16.1.141	59986		Standard query response 0x9ecf A 174.127.99.158
2017-12-23 01:42:25	174.127.99.158	2017		49177-cypress-stat [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=25
2017-12-23 01:42:25	174.127.99.158	2017		[TCP Spurious Retransmission] 49177-cypress-stat [SYN] Seq=0
2017-12-23 01:42:26	174.127.99.158	2017		[TCP Spurious Retransmission] 49177-cypress-stat [SYN] Seq=0
2017-12-23 01:42:27	174.127.99.158	2017		49178-cypress-stat [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=25
2017-12-23 01:42:28	174.127.99.158	2017		[TCP Spurious Retransmission] 49178-cypress-stat [SYN] Seq=0
2017-12-23 01:42:28	174.127.99.158	2017		[TCP Spurious Retransmission] 49178-cypress-stat [SYN] Seq=0
2017-12-23 01:42:29	174.127.99.158	2017		49179-cypress-stat [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=25
2017-12-23 01:42:30	174.127.99.158	2017		[TCP Spurious Retransmission] 49179-cypress-stat [SYN] Seq=0

All those repeated SYN packets indicate the ***gabby4u.linkpc.net*** at ***174.127.99.158*** did not respond. If you follow any of the TCP streams for those segments, you will only find TCP SYN packets. It's not much, but now we have something.

Let's search Google on ***gabby4u.linkpc.net malware*** and see what we get.



AllNewsVideosImagesShoppingMoreSettingsTools

4 results (0.43 seconds)

Alert on gabby4u.linkpc.net (Malware providers detected)

<https://map.https.com/alert/556050>

Alert #556050: "gabby4u.linkpc.net" on HTTPS Interactive cyber-attack map : Real time Website attacks, Vulnerable Websites, Malicious Websites, **Malware** providers.

Alert on www.gabby4u.linkpc.net (Malware providers detected)

<https://map.https.com/alert/558080>

Alert #558080: "www.gabby4u.linkpc.net" on HTTPS Interactive cyber-attack map : Real time Website attacks, Vulnerable Websites, Malicious Websites, **Malware** providers.

Automated Malware Analysis Executive Report for 21Payment Slip ...

<https://www.joesandbox.com/analysis/38705/0/executive>

... evasion) Detected TCP or UDP traffic on non-standard ports **gabby4u.linkpc.net** 174.127.99.158, 2017 SOFTLAYER-SoftLayerTechnologiesIncUS United States 81 similar packets combined: **gabby4u.linkpc.net** update.exe, PE32 dropped InstallUtil.exe 2 started InstallUtil.exe 2 started InstallUtil.exe started InstallUtil.exe ...

[PDF] Automated Malware Analysis Report for 21Payment ... - Joe Sandbox

<https://www.joesandbox.com/analysis/38705/0/pdf>

Nov 30, 2017 - Sample execution stops while process was sleeping (likely an evasion). Detected TCP or UDP traffic on non-standard ports **gabby4u.linkpc.net** 174.127.99.158, 2017 SOFTLAYER-

2017-12-23 TRAFFIC ANALYSIS EXERCISE: ANSWERS

We find, two search results on that domain from a sandbox analysis at www.joesandbox.com. If we review the results, we find the domain and IP address, so could this be the malware? Probably! The file name from the JoeSandbox report is **21Payment Slip.exe**, and the SHA256 file hash is a232d63b9f0afab26f61b8b627c5cdc9adcdd10fc413ac996b6bb8329815f632. Unfortunately, that file wasn't submitted to VirusTotal. A Google search on the file hash when I checked only showed the four entries on analysis from www.joesandbox.com.

Any other hints? We find one alerts from Carl's IP address (172.16.1.141) in that image on the answers page for this traffic analysis exercise. It shows **ETPRO Tempedreve Checkin** for that first HTTP request in the traffic at 176.31.127.119. Now we have a probable name for the malware.

3...	172.16.1.201	49211	74.220.219.07	80	0	ETPRO CURRENT_EVENTS Globelmposter ransomw
3...	172.16.1.201	58076	172.16.1.4	53	17	ET POLICY DNS Query to onion.proxy Domain (oni
3...	172.16.1.141	49202	176.31.127.119	80	6	ETPRO TROJAN Tempedreve Checkin

WHAT HAPPENED WITH MEATWAD ON NEWARK-1A (172.16.1.201)?

Like we did in the previous three examples, let's filter on the IP address for Meatwad. Try filtering on **ip.addr eq 172.16.1.201** and export the results to a new pcap.

Let's just filter right away on **http.request or ssl.handshake.type == 1** in the new pcap, shall we?

Filter: http.request or ssl.handshake.type == 1 Expression... Clear Apply Save						
Date/Time	Dst	port	Host	Server Name	Info	
2017-12-23 01:06:11	173.223.52.18	80	www.msftncsi.com		GET /ncsi.txt HTTP/1.1	
2017-12-23 01:06:44	52.109.120.20	443		nexus.officeapps.live.com	Client Hello	
2017-12-23 01:06:45	52.109.8.21	443		nexusrules.officeapps.live.com	Client Hello	
2017-12-23 01:16:22	67.59.136.100	80	www.bodyclassics.org		GET /tOldHSYW?YxfqXeWLCFp=Y	
2017-12-23 01:17:22	74.220.219.67	80	psoeiras.net		GET /js/count.php?nu=105&fb=	
2017-12-23 01:17:25	103.198.0.2	443		topyzscsu5poprxy.onion.link	Client Hello	
2017-12-23 01:17:25	103.198.0.2	443		topyzscsu5poprxy.onion.link	Client Hello	
2017-12-23 01:17:27	204.79.197.200	80	www.bing.com		GET /favicon.ico HTTP/1.1	
2017-12-23 01:17:52	72.21.81.200	443		iecvlist.microsoft.com	Client Hello	
2017-12-23 01:17:52	72.21.81.200	443		iecvlist.microsoft.com	Client Hello	
2017-12-23 01:17:55	216.58.194.106	443		ajax.googleapis.com	Client Hello	

In the results, we find HTTPS traffic to **topyzscsu5poprxy.onion.link** and HTTP traffic to **psoeiras.net**. That should be familiar to anyone who reviews traffic from my blog. Those domains are routinely associated with Necurs Botnet malspam pushing Globelmposter ransomware. I posted a recent example on 2017-12-26 ([link](#)), where you can see the similar traffic.

We also find several alerts from 172.16.1.201 in that image on the answers page for this traffic analysis exercise.

2017-12-23 TRAFFIC ANALYSIS EXERCISE: ANSWERS

-23...	172.16.1.89	49197	185.22.184.127	443	0	ETPRO TROJAN Observed malicious mailDOC DE Domain in SNI (te...
-23...	172.16.1.89	49198	216.146.43.70	80	6	ET POLICY External IP Lookup - checkip.dyndns.org
-23...	172.16.1.201	49209	67.59.136.100	80	6	ET POLICY Internet Explorer 6 in use - Significant Security Risk
-23...	67.59.136.100	80	172.16.1.201	49209	6	ETPRO TROJAN Locky JS Executable Payload Download
-23...	67.59.136.100	80	172.16.1.201	49209	6	ET TROJAN VMProtect Packed Binary Inbound via HTTP - Likely Ho...
-23...	172.16.1.201	49209	67.59.136.100	80	6	ET POLICY Unsupported/Fake Windows NT Version 5.0
-23...	172.16.1.201	49209	67.59.136.100	80	6	ET CURRENT_EVENTS Nemucod JS Downloader Aug 01 2017
-23...	67.59.136.100	80	172.16.1.201	49209	6	ET POLICY PE EXE or DLL Windows file download
-23...	67.59.136.100	80	172.16.1.201	49209	6	ET POLICY Binary Download Smaller than 1 MB Likely Hostile
-23...	172.16.1.201	49211	74.220.219.67	80	6	ETPRO CURRENT_EVENTS GlobeImposter Ransomware Note Cou...
-23...	172.16.1.201	58076	172.16.1.4	53	17	ET POLICY DNS Query to .onion proxy Domain (onion.link)
-23...	172.16.1.141	49202	176.31.127.119	80	6	ETPRO TROJAN Tempedreve Checkin

Of note, don't get hung up on that second alert that shows "Locky" in the alert title. Earlier this year, the Necurs Botnet was pushing Locky ransomware. However, as of December 2017, we haven't seen any new samples, and Locky seems to have disappeared for now. The Necurs Botnet is currently pushing GlobeImposter ransomware as I write these answers.

And that concludes my tips to find the answers. I hope this has been helpful, and I wish everyone has a great year as we head into 2018!